

Averray Mainnet Audit Re-Verification Report

Independent remediation verification against frozen git tag `audit/mainnet-2026-07-07`

Repository commit: `fd9b306b8d0c5e26c338b4806545cba20dbb0872`

Report Date	2026-07-08
Audited Repository	/tmp/avarray-audit (frozen tag <code>audit/mainnet-2026-07-07</code>)
Commit Hash	<code>fd9b306b8d0c5e26c338b4806545cba20dbb0872</code>
Audit 1 (Solo External)	2026-06-30 — 0 Critical · 7 High · 12 Medium · 14 Low · 18 Info
Audit 2 (Multi-Agent Contract)	2026-07-02 — 0 Critical · 2 High · 8 Medium · 15 Low · 5 Info
Re-Verification Date	2026-07-08
Verification Method	Source code inspection at frozen tag + git log PR verification + backend/ops file review
Verifier	Independent re-verification (Ash / OpenClaw)

Overall Re-Verification Verdict: CONDITIONAL PASS — All Critical and High findings from both audits are remediated and merged at the frozen tag. 1 backend finding (D-03) remains PARTIAL (CI auto-deploy gate is code-level only; broad GitHub required-reviewers human gate not yet implemented). A set of Low-severity items are intentionally deferred as acceptable for a capped launch. XCM/vDOT strategy settlement remains disabled and requires separate enablement proof.

1. Executive Summary

This report documents an independent re-verification of all remediations from two security audits performed against the Averray mainnet codebase. The verification was conducted by inspecting source code at the frozen git tag `audit/mainnet-2026-07-07` (commit `fd9b306`), cross-referencing git merge history for 33+ remediation PRs, and reviewing backend/operations files.

Audit 1 — Solo External Auditor (2026-06-30)

Verdict: **Conditional Mainnet Approval**. 0 Critical · 7 High · 12 Medium · 14 Low · 18 Informational. Core escrow/settlement logic rated "well-designed with strong idempotency guarantees." KMS/EIP-712 signing rated "exemplary." 13/14 critical invariants PASS.

Audit 2 — Deep Multi-Agent Contract Audit (2026-07-02)

Verdict: **Medium-High — mainnet gated on remediation**. 0 Critical · 2 High · 8 Medium · 15 Low · 5 Informational. Core escrow/settlement re-affirmed solid. All 30 findings verified: 29 CONFIRMED, 1 PARTIAL (H-1 sub-claim (a) overstated, net effect holds).

Re-Verification Summary

Smart Contract Findings (Audit 1 + Audit 2):

- Audit 1 Highs (7): C-01 → H-1 ☐PASS · C-02 → H-2 ☐PASS · C-03 → L-2 ☐PASS · C-18 → L-3 ☐PASS · B-01 ☐PASS · B-11 ☐PASS · D-01 ☐PASS
- Audit 2 Highs (2): H-1 ☐PASS · H-2 ☐PASS
- Audit 2 Mediums (8): M-1 through M-8 — all ☐PASS
- Audit 2 Merged Lows: L-2, L-3, L-6, L-7, L-8, L-9 — all ☐PASS
- Audit 2 Info I-5: ☐PASS

Backend / Ops Findings (Audit 1):

- B-01 ☐PASS · B-11 ☐PASS · D-01 ☐PASS · B-02 ☐PASS · B-03 ☐PASS · B-04 ☐PASS · D-02 ☐PASS · E-17 ☐PASS · D-04 ☐PASS

PARTIAL:

- D-03 (CI auto-deploy without manual gate) — **PARTIAL**: Contract-surface drift now fails-closed on auto-deploys; broad GitHub required-reviewers human gate remains a separate optional hardening.

Acceptable Deferrals (capped launch):

- Audit 1 Mediums: C-04, C-05, C-09, C-12, C-15
- Audit 2 Lows: L-4, L-5, L-10, L-11, L-13, L-14, L-15
- Audit 2 Info: I-4
- Deferred by decision: L-1 (finite-cap arming), L-12 (lending finish-or-remove), I-1, I-2, I-3

2. Audit 1 — High Findings (7)

The solo external auditor identified 7 High-severity findings that must be addressed before mainnet. All are remediated and merged.

ID	FINDING	OWNER	VERDICT	REMEDIATION	EVIDENCE
C-01	Daily outflow cap defaults to <code>type(uint256).max</code> — no on-chain protection	Codex	PASS	Re-implemented as audit-2 H-1: breaker now meters real egress only (withdraw, external-recipient strategy-withdraw, transferred slash legs), per-account/day, non-halting. PRs #717 + #718 merged.	<code>TreasuryPolicy.sol</code> constructor: <code>dailyOutflowCap = type(uint256).max (default)</code> . <code>AgentAccountCore.withdraw()</code> now calls <code>policy.recordOutflow(msg.sender, amount).settleReservedTo()</code> no longer calls <code>recordOutflow</code> . Per-account metering confirmed.
C-02	Slashed treasury portion recorded but never transferred → funds trapped in AAC	Codex	PASS	Re-implemented as audit-2 H-2: owner-settable <code>treasuryAccount</code> credits slashed portions; fail-closed while unset; recoverable via metered withdraw. PR #718 merged.	<code>AgentAccountCore._creditTreasury</code> reverts if <code>treasuryAccount == address(0)</code> (<code>TreasuryAccountUnset</code>). Credits to <code>positions[treasuryAccount][asset].liquid.slashJobStake</code> and <code>slashClaimFee</code> call <code>_creditTreasury</code> treasury portion.
C-03	AAC must be <code>serviceOperator</code> or all slashing reverts (silent deploy dependency)	Codex	PASS	Re-implemented as audit-2 L-2: role-split replaces broad <code>serviceOperators</code> with 5 least-privilege roles. Deploy finalization asserts <code>outflowRecorder(newAAC)</code> . PR #724 merged.	<code>TreasuryPolicy.sol</code> has separate role mappings: <code>outflowRecorder</code> , <code>settlementBroker</code> , <code>agentTransferBroker</code> , <code>strategySettler</code> , <code>reputationWriter</code> . Old broad <code>serviceOperators</code> removed.
C-18	<code>workerClaimCount</code> never decrements → workers permanently penalized for timeouts	Codex	PASS	Re-implemented as audit-2 L-3: <code>handleClaimTimeout</code> restores one onboarding-waiver slot for claimed-but-never-submitted timeouts. PR merged.	<code>EscrowCore.handleClaimTimeout</code> captures timed-out worker before clearing claim fields, slashes against that worker, restores one onboarding-waiver slot with underflow guard.
B-01	Auto-verifier triggers settlement in-process, bypassing JWT auth	Claude	PASS	Every autonomous settlement + verdict ingestion now logged under synthetic principal <code>system:auto-verifier</code> . Defense in depth: <code>requireChainBackedMutation</code> , <code>hard {benchmark, deterministic}</code> mode allowlist, HALT-aware, idempotent settlement keys. PR #711 merged.	<code>submitted-job-auto-verifier.js</code> settlement triggered through same <code>verifySubmission</code> path as manual request. Synthetic principal logged. Mode allowlist enforced.
B-11		Claude	PASS		

	Autonomous verdict ingestion has no auth			Same trust model as B-01: trusted in-process scheduler, synthetic principal logging, chain- backed mutation gate, idempotent keys. PR #711 merged.	verification-ingestion-service autonomous ingestion logged under verification_ingest.autonomous JWT bypass — same resolveSinglePayout path as manu
D-01	Long-lived 1Password service- account tokens (4)	Pascal/ infra	PASS	Smoke + CI re-rotated at env scope + repo shadows deleted. Old tokens revoked + 7 duplicate service accounts pruned (13 → 6, one SA per role). Verified 2026-06-30.	Scope-verified 2026-06-30. 1Password service accounts reduced from 13 to 6 tokens revoked. Rotation script scrip ops/rotate-sa-token.mjs in place.

3. Audit 1 — Medium Findings (12)

ID	FINDING	OWNER	VERDICT	REMEDIATION / STATUS	PR
B-02	HS256 testnet JWT — add mainnet SIGNER_BACKEND=kms startup assertion	Claude	PASS	assertMainnetSignerPosture fails boot closed on mainnet + local signer.	#711
B-03	Grant cache 15s staleness on revocation	Claude	PASS	Mutating requests use 2s grant-cache TTL (reads keep 15s). Cross-process revoke stops authorizing state changes within ~2s.	#712
B-04	X-Forwarded-For spoofing under TRUST_PROXY	Claude/ infra	PASS	Caddy overwrites XFF with real peer IP (strip_forwarded_for snippet). extractClientKey keys on rightmost (proxy-appended) hop. caddy validate clean.	#714
D-02	Chain-ID mismatch risk	Claude/ infra	PASS	assertChainIdMatchesRpc fails closed on confirmed mismatch (warns if RPC unreachable).	#711
D-03	CI auto-deploy without manual gate	Pascal/ infra	PARTIAL	Contract-surface drift now fails-closed on auto-deploys. Override is dispatch-only allow_contract_surface_drift=1. A broad GitHub "required reviewers" human gate remains a separate optional hardening.	#706
E-17	JS Number for off-chain USDC math (systemic)	Claude	PASS	Authoritative treasury/settlement/strategy accounting was already BigInt. Closes residual projection-layer Number math: claim-economics.js bps stake/fee and estimateNetReward now compute in integer base units.	#713
D-04	Missing Caddyfile security headers	Claude/ infra	PASS	HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy on every Caddy site. Strict CSP default-src 'none'; frame-ancestors 'none' on JSON API + indexer.	#715
C-04	sendToAgent lacks nonReentrant (defense-in-depth)	Codex	DEFERRED	Acceptable deferral for capped launch. Defense-in-depth guard.	—
C-05	recordOutflow lacks nonReentrant	Codex	DEFERRED	Acceptable deferral for capped launch. Defense-in-depth guard.	—

C-09	XcmWrapper async request ledger has no expiry	Codex	DEFERRED	Also audit-2 L-5. XCM disabled for mainnet; not on launch gate.	—
C-12	No upper bound on minimumCollateralRatioBps	Codex	DEFERRED	Parameter bounds check. Acceptable for capped launch.	—
C-15	Zero-reward jobs allowed → queue grieving	Codex	DEFERRED	Single-payout variant deferred; milestone variant fixed via audit-2 M-3.	—

4. Audit 1 — Low Findings (14)

All Low findings are fix-opportunistically/post-launch unless otherwise noted.

ID	FINDING	VERDICT	NOTES
C-06	Per-contract ReentrancyGuard	DEFERRED	Each contract has own guard; acceptable.
C-10	finalizeXcm permissionless	DEFERRED	XCM disabled for mainnet.
C-13	Pause blocks slashing	PASS	Fixed via audit-2 M-6. Failed/cancelled deposit refunds can settle while paused.
C-14	Milestone spam within cap	DEFERRED	Low priority.
C-17	autoResolveOnTimeout favors worker	PASS	Fixed via audit-2 M-2. Half-reward timeout payout, no badge.
B-06	Payment asset defaults to DOT	DEFERRED	Low priority config.
B-12	Verifier-result endpoint public	DEFERRED	Low priority.
E-10	Economic edge case	DEFERRED	Low priority.
E-18	Economic edge case	DEFERRED	Low priority.
E-21	Economic edge case	DEFERRED	Low priority.
E-24	Economic edge case	DEFERRED	Low priority.
E-26	Economic edge case	DEFERRED	Low priority.
E-27	Economic edge case	DEFERRED	Low priority.
D-04	Missing Caddyfile security headers	PASS	HSTS + security headers + strict CSP. PR #715 merged.

5. Audit 2 — High Findings (2)

H-1: Daily-outflow circuit-breaker meters wrong thing — PASS

Finding: The daily-outflow circuit-breaker (`TreasuryPolicy.recordOutflow / dailyOutflowCap`) was metering internal book-transfers, not real ERC20 egress. `withdraw()` — the primary path that actually transfers tokens out — never called `recordOutflow`. Meanwhile `settleReservedTo()` (a pure book-move where tokens never leave the contract) did call it, inflating the counter and potentially halting settlement.

Remediation (MERGED #717 + #718):

- `withdraw()` now calls `policy.recordOutflow(msg.sender, amount)` on real ERC20 egress
- External-recipient strategy-withdraw settlements and transferred slash legs also meter real egress
- `settleReservedTo()` no longer calls `recordOutflow` (book-move, tokens stay in-contract)
- Per-account/day metering: one account's breach cannot halt unrelated settlement
- `recordProtocolOutflow` bypasses cap enforcement (cap-exempt slash egress)
- Role-split: broad `serviceOperators` replaced by 5 least-privilege roles

Source Evidence:

- `AgentAccountCore.sol withdraw()` (line ~223-229): calls `policy.recordOutflow(msg.sender, amount)` after `SafeTransfer`
- `TreasuryPolicy.sol recordOutflow`: per-account metering with `accountOutflowDay / accountOutflowToday` mappings
- `TreasuryPolicy.sol recordProtocolOutflow`: `enforceCap = false` path for protocol slash egress
- Constructor: `dailyOutflowCap = type(uint256).max` (unarmed by default — must not be set finite until split-role/cap-exempt follow-on is live)

⚠ **Launch-critical note:** A finite `DAILY_OUTFLOW_CAP` must NOT be armed until the split-role/cap-exempt slash follow-on is also live. This is a config-discipline gate, not a code gate.

H-2: Slashed treasury portion trapped in AAC — PASS

Finding: `slashJobStake` and `slashClaimFee` called `recordOutflow` for the treasury portion but never actually transferred the tokens — funds were permanently trapped. `handleClaimTimeout` with `verifierRecipient == address(0)` sent the full claim fee to a non-existent treasury sink.

Remediation (MERGED #718):

- Owner-settable `treasuryAccount` (in-contract liquid balance)
- `_creditTreasury()` credits slashed portions to treasury account
- Fail-closed: reverts with `TreasuryAccountUnset()` if `treasuryAccount == address(0)`
- Recoverable via normal metered `withdraw`
- Deploy script asserts `treasuryAccount()` is non-zero before finalizing

Source Evidence:

- `AgentAccountCore._creditTreasury(address asset, uint256 amount):` if (account == address(0)) revert TreasuryAccountUnset(); positions[account][asset].liquid += amount; emit TreasuryCredited(...)
- `slashJobStake:` splits amount into posterAmount = amount / 2 (50% poster) and treasuryAmount (remainder), credits treasury via `_creditTreasury`
- `slashClaimFee:` same pattern with verifier/treasury split

6. Audit 2 — Medium Findings (8)

ID	FINDING	CONTRACT	VERDICT	REMEDICATION	PR	RECONCILIATION
M-1	Debt double-count across buckets — raw liquid < amount ignores debt	AgentAccountCore	PASS	Four raw-liquid guards now route through debt-aware check (liquid - debtOutstanding) via _requireWithdrawable. Borrowed debt isn't double-counted as spendable.	#719	New
M-2	autoResolveOnTimeout favors worker — full payout on timeout	EscrowCore	PASS	Timeout auto-resolution pays half unreleased reward, refunds rest to poster, slashes claim economics, skips badge mint. No merit-free full payout.	#720	= C-17
M-3	Zero-amount milestone wedges job	EscrowCore	PASS	createMilestoneJob now reverts on any milestones[i] == 0. Zero-amount milestones can't wedge the job lifecycle.	#720	New
M-4	XcmWrapper finalizer not bound to queue-time caller + no amount validation	XcmWrapper	PASS	Stores queuedBy; finalizer requires msg.sender == queuedBy owner. Deposit/withdraw settlement bounds validated before latching.	#721	New
M-5	Operator-echoed share price / no on-chain decimal normalization	XcmVdotAdapter	PASS	Deposit shares derived from on-chain totals (totalAssets / totalShares). Withdraw assets capped to pro-rata share value. Operator can't supply off-ratio amounts.	#721	New
M-6	Pause blocks strategy refund — in-flight deposits trapped	AgentAccountCore / XcmVdotAdapter	PASS	Failed/cancelled deposit settlement refunds can clear through AAC entrypoint while paused. Successful settlement remains pause-blocked.	#721	= C-13
M-7	Registry silent adapter re-point	StrategyAdapterRegistry	PASS	registerStrategy now rejects silent adapter re-pointing for known strategy ID: if	#721	New

				(strategyKnown[id] && strategies[id].adapter != adapter) revert. Explicit migration remains a future flow.		
M-8	Claim stake not re-scoped after partial milestone release	EscrowCore	PASS	Re-Claim path re-scopes job.claimStake to (job.reward - job.released) and releases excess locked stake. Final-milestone timeout slashes only remaining-reward-scaled stake.	#720	New

7. Audit 2 — Low Findings (15)

ID	FINDING	VERDICT	STATUS / NOTES
L-1	Default caps type(uint256).max	DEFERRED	Do NOT arm finite dailyOutflowCap until H-1 split-role/cap-exempt follow-on lands. Gated on H-1.
L-2	Silent deploy dependency on outflowRecorder	PASS	Deploy finalization asserts outflowRecorder(newAAC) + role-split broker grants. PR #724 merged.
L-3	workerClaimCount never restored on timeout	PASS	handleClaimTimeout restores one onboarding-waiver slot. Underflow guard. PR merged.
L-4	SafeTransfer to codeless address silently succeeds	DEFERRED	Acceptable deferral. Add extcodesize > 0 guard.
L-5	XcmWrapper request has no expiry/cancel	DEFERRED	XCM disabled for mainnet. = C-09.
L-6	XcmWrapper trusts raw XCM bytes, no decode	PASS	Now decodes SCALE XCM payload: asserts WithdrawAsset asset/amount + DepositAsset beneficiary. Lockstep with backend builder. PRs #728 + #729 merged.
L-7	Registry doesn't propagate TreasuryPolicy de-approval	PASS	getStrategy now reports inactive when policy.approvedStrategies(adapter) revoked. PR merged.
L-8	Registry doesn't validate approvedAssets	PASS	registerStrategy now requires policy.approvedAssets(assetAddr). PR merged.
L-9	Operator can redirect strategy-withdraw recipient	PASS	Operator-initiated strategy withdrawals can only return to account/AAC. Account-initiated keeps explicit recipient. PR merged.
L-10		DEFERRED	

	Reputation overwrite not accumulate		Acceptable deferral. Accumulate instead of full-struct overwrite.
L-11	Silent debt repay inside settlement, no event	DEFERRED	Acceptable deferral. Emit debt-repayment event.
L-12	Half-wired lending, no liquidation	DEFERRED	Deferred by decision. Finish or remove borrow/repay/debtOutstanding.
L-13	Fee-on-transfer over-credit on deposit	DEFERRED	Acceptable deferral. Measure balance delta before/after.
L-14	Single-step publisher rotation	DEFERRED	Acceptable deferral. Add two-step setPendingPublisher/acceptPublisher.
L-15	Unbounded verifier-window view DoS	DEFERRED	Lowest priority. View-only, no fund path.

8. Audit 2 — Informational (5)

ID	FINDING	VERDICT	STATUS
I-1	SafeTransfer strictness on return data	DEFERRED	Documentation choice. Intentional strictness.
I-2	SafeTransfer approve no reset-to-zero-first	DEFERRED	Documentation choice. USDT-style tokens would revert.
I-3	XcmWrapper compact mode 3 rejection	DEFERRED	Benign. XCM counts never need mode-3.
I-4	ReputationSBT zero-address guard + economic unit	DEFERRED	Acceptable deferral. Add account != address(0).
I-5	StrategyAdapterRegistry setStrategyActive guard	PASS	Now guards if (!strategyKnown[strategyId]) revert StrategyNotApproved(). PR #721 merged.

9. Architectural & Centralization Findings

Role Split — PASS

The former overloaded `serviceOperators` role has been split into five least-privilege roles:

- `settlementBroker` — escrow settlement operations
- `agentTransferBroker` — agent transfer operations
- `strategySettler` — XCM strategy settlement (stays ungranted while XCM disabled)
- `reputationWriter` — reputation SBT updates
- `outflowRecorder` — outflow metering enforcement

`recordOutflow` is now an enforcing `outflowRecorder` path. `recordProtocolOutflow` uses record-only (cap-exempt) so penalized accounts cannot self-DoS penalties. PRs #724 (contract) + #726 (backend) + #727 (ops) merged.

Owner → Multisig — PENDING DEPLOY

All owner-only setters (caps, verifier/operator/pauser/arbitrator roles, strategy approvals, treasury sink) must resolve to the mapped 2-of-3 multisig before mainnet. This is a deploy ceremony step, not a code fix. Documented in `LAUNCH_CRITICAL_PATH.md`.

XCM Operator Trust — DISABLED FOR MAINNET

`XcmWrapper.finalizeRequest`, `XcmVdotAdapter.settleRequest`, and `StrategyAdapterRegistry` collectively let an operator supply terminal status, settled amounts, share prices, and adapter state. L-6's raw-byte trust is now merged with decoded asset/amount/beneficiary assertions, but remote-outcome proof is still absent. XCM vDOT stays **disabled for mainnet** until native observer correlation is live.

10. Git Merge Verification

All 33+ remediation PRs were verified as merged at the frozen git tag `audit/mainnet-2026-07-07` (commit `fd9b306`):

PR	FINDING	DESCRIPTION
#688	MAIN-006	EIP-712 authorization for <code>sendToAgentFor</code> + debt-aware withdrawable
#706	D-03	Contract-surface drift fails-closed on auto-deploys
#711	B-01, B-11, B-02, D-02	Auto-verifier auth model, JWT signer assertion, chain-ID check
#712	B-03	Grant cache 2s TTL for mutations
#713	E-17	BigInt projection-layer USDC math
#714	B-04	XFF spoofing fix (Caddy strip + rightmost-hop keying)
#715	D-04	Caddyfile security headers + strict CSP
#717	H-1 (C-01)	Outflow breaker re-wire: meter real egress only
#718	H-1 + H-2	Per-account metering + treasury sink
#719	M-1	Debt-aware reserve guards
#720	M-2, M-3, M-8	Escrow timeout economics + zero-milestone + claim stake re-scope
#721	M-4, M-5, M-6, M-7, I-5	XCM/strategy: finalizer binding, on-chain shares, paused refund, no silent re-point, <code>setStrategyActive</code> guard
#722	Backend M-4 ABI	Backend ABI realignment
#724	Role split	Contract role-split: 5 least-privilege roles
#725	Gas fee buffer	Gas-fee buffer + ED-safe funding
#726	Backend roles	Backend role-aware health checks
#727	Ops roles	Ops role provisioning
#728	L-6	XcmWrapper SCALE decode + asset/amount/beneficiary assertions
#729	L-6	XcmWrapper lockstep with backend builder
#730	Backend L-6 + M-5	Backend settlement correlate: BigInt precision + ratio preflight
#739	L-7, L-8, L-9	Registry: policy de-approval propagation, <code>approvedAssets</code> validation, withdraw recipient constraint

Additional PRs #707, #732–#738, #740–#747 also verified as merged (supporting fixes, ops updates, deploy script changes, documentation).

11. Pre-Audit Internal Review Findings

An internal multi-agent security pass on 2026-06-25 found 8 findings (1 Critical, 2 High, 3 Medium, 2 Low). All contract findings are remediated in code (PRs #688–#695) and merged at the frozen tag.

ID	SEVERITY	FINDING	VERDICT	PR	NOTES
MAIN-006	Critical	sendToAgentFor only onlyOperator — compromised backend could drain any user's balance	PASS	#688	EIP-712 authorization (signature + nonce/deadline replay guard)
—	High	Debt-backed credit externally withdrawable	PASS	#688	_requireWithdrawable enforces liquid - debtOutstanding
—	Medium	Recurring-template cancellation/refund path	PASS	#689	Merged
—	Medium	Onboarding stake/fee waiver too broad	PASS	#690	Gated to onboardingWaiverEligibleJobs only
—	Low	_refreshStrategyAllocated unbounded loop	PASS	#691	Replaced by touched-only _syncStrategyAllocation
—	Low	External-schema signatures not EIP-712 domain-bound	PASS	#692	EIP-712 domain with chainId + address(this)

12. Static Analysis Baseline

Slither 0.11.4 (2026-06-25): 0 high · 26 medium · 18 low · 14 info/optimization across in-scope contracts. Mediums are standard categories (reentrancy-benign/-events behind nonReentrant, block-timestamp for deadlines, missing-zero-address-validation). No critical static red flags. Static analysis does not cover logic/economic bugs — the Critical (sendToAgentFor) was invisible to it.

13. Critical Invariants (14)

The audit package defines 14 critical invariants. Verification status at the frozen tag:

#	INVARIANT	VERDICT	NOTES
1	Funds are never double-spent	PASS	Idempotent 2-layer settlement (settlementExecuted mapping + keccak256(jobId, index, amount) keys)
2	Job state machines cannot be skipped	PASS	State transition guards in EscrowCore
3	Claims are mutation-safe	PASS	Retry accounting + claim-state machine
4	Idempotency is bound to actor and payload	PASS	buildIdempotentMutationContext + runIdempotentMutation helpers
5	Service tokens cannot escape their grant	PASS	capabilityGrantId scoping
6	Verifier replay is stable	PASS	Policy/config drift detection
7	Pause halts value movement	PASS	whenNotPaused on all value-moving functions (except M-6 refund path — by design)
8	The pauser cannot administer funds	PASS	Pauser role is separate from owner/treasury/verifier
9	USDC accounting uses raw base units	PASS	BigInt throughout (E-17 fix); 6-decimal raw units
10	Mainnet env cannot reuse testnet keys	PASS	Env/secrets proof scripts; mainnet.env.example
11	Native account mapping is explicit	PASS	map_account() evidence requirement documented
12	Observability does not leak secrets	PASS	No private keys/tokens in logs/events; /admin/ status redacted
13	Autonomous verification cannot over-settle	PASS	Hard {benchmark, deterministic} allowlist; HALT-aware; idempotent keys; no fake-settled state
14	Discovery never advertises unfunded job as claimable	PASS	INGESTION_PREFUND_ENABLED; fundingState: pending → claimable: false

14. Verification Methodology

The re-verification was conducted using the following methods:

- **Git log inspection:** All 33+ remediation PRs verified as merged at commit fd9b306 (tag audit/mainnet-2026-07-07)
- **Source code inspection:** Contract Solidity files (AgentAccountCore.sol, TreasuryPolicy.sol, EscrowCore.sol, XcmWrapper.sol, XcmVdotAdapter.sol, StrategyAdapterRegistry.sol, ReputationSBT.sol, DiscoveryRegistry.sol, SafeTransfer.sol, ReentrancyGuard.sol) reviewed at the frozen tag
- **Backend/ops file review:** Key backend files (submitted-job-auto-verifier.js, verification-ingestion-service.js, gateway.js, claim-economics.js, Caddyfile, deploy scripts) reviewed
- **Documentation review:** AUDIT_PACKAGE.md, MAINNET_AUDIT_REMEDIATION.md, MAINNET_AUDIT_2_REMEDIATION.md, AUDIT_REMEDIATION.md, AVERRAY_VERIFICATION_LEDGER.md reviewed
- **Cross-reference:** Each finding reconciled between Audit 1 and Audit 2 boards (H-1 → C-01, H-2 → C-02, M-2 → C-17, M-6 → C-13, L-2 → C-03, L-3 → C-18, L-5 → C-09)

15. Open Items & Launch Gates

The following items remain open before mainnet deployment can proceed:

Must-Fix Before Mainnet (Code — All DONE)

- ☒ All 7 Audit-1 Highs — remediated and merged
- ☒ All 2 Audit-2 Highs — remediated and merged
- ☒ All 8 Audit-2 Mediums — remediated and merged
- ☒ All pre-audit internal review findings (MAIN-006 etc.) — remediated and merged

Must-Fix Before Mainnet (Deploy/Ops)

- ⚠ Owner → multisig: transfer all owner-only setters to 2-of-3 multisig during deploy ceremony
- ⚠ Treasury sink: set AgentAccountCore.setTreasuryAccount(<treasury/multisig>) before finalizing paired manifest
- ⚠ Split-role provisioning: grant outflowRecorder, settlementBroker, agentTransferBroker, reputationWriter
- ⚠ Do NOT arm finite DAILY_OUTFLOW_CAP until split-role/cap-exempt slash follow-on is confirmed live
- ⚠ Fresh mainnet multisig, KMS keys, service tokens — no testnet reuse
- ⚠ Mainnet USDC config proof, env/secrets proof, smoke proof, incident-response proof

Acceptable Deferrals (Capped Launch)

- Audit-1 Mediums: C-04, C-05, C-09, C-12, C-15 — defense-in-depth + parameter bounds
- Audit-2 Lows: L-4, L-5, L-10, L-11, L-13, L-14, L-15 — none on Critical/High gate
- Audit-2 Info: I-4 — zero-address guard + economic unit documentation

- Deferred by decision: L-1 (finite-cap arming), L-12 (lending), I-1, I-2, I-3

Post-Launch / XCM Enablement Gate

- XCM vDOT settlement stays disabled until: (a) native observer correlation is live, (b) one real testnet `queueRequest` dispatch proof, (c) `strategySettler` role granted
- Backend XCM settlement correlate (L-6 + M-5): merged but not yet testnet-proven

Backend Follow-on (Not Launch-Blocking)

- D-03 PARTIAL: Broad GitHub "required reviewers" human gate remains optional hardening
- Backend role-aware health checks against split roles (follow-on after Codex defines roles — now merged #726)
- Indexer consumes new events (e.g. L-11 debt-repayment event — follow-on)

16. Final Verdict

Re-Verification Verdict: **CONDITIONAL PASS**

All Critical and High findings from both audit passes are remediated, merged, and verified at the frozen git tag `audit/mainnet-2026-07-07` (commit `fd9b306`). All 8 Audit-2 Mediums are remediated and merged. The single PARTIAL finding (D-03) is a CI hardening measure where the code-level fix is in place but a broad human gate remains optional.

The remaining open items are deploy/ops ceremony steps (multisig transfer, role provisioning, treasury sink assignment, cap discipline) and acceptable deferrals for a capped launch. No code-level remediation remains open on the Critical/High gate.

Conditions for mainnet deployment:

1. Deploy contracts from the audited artifact set
2. Transfer ownership to 2-of-3 multisig
3. Assign split roles and set treasury sink
4. Do NOT arm finite `dailyOutflowCap` until split-role/cap-exempt follow-on confirmed
5. Complete mainnet env/secrets/smoke/incident-response proofs
6. Keep XCM vDOT disabled until native observer correlation is live

Report generated 2026-07-08 by independent re-verification (Ash / OpenClaw).

Source repository: `/tmp/averray-audit` at tag `audit/mainnet-2026-07-07`.

Audit 1 source: `docs/MAINNET_AUDIT_REMEDIATION.md`.

Audit 2 source: `docs/MAINNET_AUDIT_2_REMEDIATION.md`.

Audit package: `docs/AUDIT_PACKAGE.md`.

Internal review: `docs/AUDIT_REMEDIATION.md`.

Verification ledger: `docs/AVERRAY_VERIFICATION_LEDGER.md`.